

PS-DOS

A secure, multi-tenant delivery operating system for professional-services firms — built for operational certainty and frictionless stakeholder visibility, on an architecture where isolation and least-privilege access are enforced at the database and the framework edge, not in the UI.

RELEASE	COMMIT	DATE	STATUS
v1.16.0	e1a0c09	2026-09-07	Production · healthy

01 THE PROBLEM WE SOLVE

Professional-services delivery leaders are forced into a false choice.

Spreadsheets and slideware are fast to start but fragile, un-auditable, and impossible to trust at portfolio scale. Numbers drift, versions fork, and there is no record of who changed what.

General-purpose PM and ERP platforms either bolt “security” onto a UI layer that a determined user can walk around, or hand operators raw database and infrastructure access and call it power-user mode.

Neither gives a sponsor **operational certainty** — a single, current, tamper-evident view of engagement health, financial realization, and governance — without also widening the attack surface.

THE A2R POSITION

PS-DOS removes the choice. It delivers the portfolio, financial, and governance model of a purpose-built PS platform on an architecture that enforces tenant isolation, auditability, and least-privilege operator access where they cannot be bypassed — at the database and the edge.

02 WHAT PS-DOS IS

A multi-tenant SaaS platform that gives the vendor and every client tenant one current, governed view of delivery.

CAPABILITY	WHAT IT DELIVERS
Portfolio governance	PS Control Tower, RBAC-scoped portfolios, SteerCo briefings, and a decision ledger.
Engagement delivery	Commercial Baseline (sizing and rate card), Control Audit (weighted scoring), RAID, Schedule and Milestones.
Financial realization	EAC, BAC, and margin-drift with exact-decimal arithmetic — no floating-point error at portfolio scale.
Capacity planning	Utilization, concurrency radar, 52-week forecast, holiday and policy controls.
Stakeholder visibility	Executive Briefing Hub, print-ready board packs, and a strict read-only Viewer tier for guests and clients.
Operator control plane	An internal console for the vendor — tenant lifecycle, telemetry, platform health — under a six-tier least-privilege role model.

Stack. Next.js 15 (App Router), NextAuth v4, Prisma 5.22, and PostgreSQL 17 (Supabase), deployed on Vercel at www.a2rventures.com. Production is healthy and continuously verified.

03 OPERATIONAL CERTAINTY & FRICTIONLESS VISIBILITY

The two outcomes the platform is designed around — one for the operator, one for the stakeholder.

CERTAINTY FOR THE OPERATOR

One current source of truth. Every currency and rate figure is computed in exact decimal and rounded once, at its accounting boundary — the number on screen is the number that is stored. A locked baseline is the immutable reference every future comparison measures against.

VISIBILITY FOR THE STAKEHOLDER

A dedicated read-only Viewer tier: whole-org read of the portfolio and the SteerCo board, zero edit authority, every financial figure scrubbed server-side. Guests and clients see the picture without ever touching it — and without a bespoke export.

Governance is configurable per tenant — compliance templates toggle module visibility and financial masking — so the same platform fits a board-reporting engagement and a hands-on delivery team without a fork.

04 SECURITY POSTURE AT A GLANCE

PS-DOS reached v1.16.0 through seven successive audit-and-hardening rounds. The full architecture is documented separately in the **Multi-Tenant Security Briefing**; in summary:

- **Tenant isolation** is enforced at four independent layers, including PostgreSQL row-level security — one client's data is never one bug away from another's.
- **Cryptographic key separation** — the MFA secret is sealed under a dedicated, versioned key, fully decoupled from the session-signing secret, with zero-downtime rotation.
- **Atomic replay protection** — second-factor consumption is a single conditional database write plus a row lock; a replayed code can never yield a second privileged session.
- **Three-layer operator RBAC** across six least-privilege tiers, plus isolated guest observers — enforced at the edge, the page, and the action.
- **Engine-level audit immutability** — the hash-chained ledger cannot be altered even by the application's own database role.

COMPLIANCE ALIGNMENT

PS-DOS is designed and operated in alignment with SOC 1 and SOC 2 control objectives — logical access control, change management, segregation of duties, and a tamper-evident audit trail. This is control-design alignment demonstrated by the repository's own evidence artifacts; no third-party SOC attestation has been performed, and this document claims none.

05 VERIFICATION (V1.16.0)

Every gate below was run against the production commit on the staging database. The automated suites cannot target production.

TYPE CHECK 0	LINT 0 / 0	UNIT + DB 693	END-TO-END 65
BUILD clean	PROD RLS pass	PROD HEALTH ready	MIGRATIONS 0-25

Vitest across 59 files; Playwright across Suites A–Q; both on the staging database — a hard guard aborts any run whose resolved URL is the production project. The production posture is verified read-only. Every release tag from [v1.12.0](#) points at the exact immutable commit deployed to production.

06 PRODUCT ROADMAP — NEXT RELEASE FOR BETA CLIENTS

Three themes, sequenced Pulse → telemetry → widgets; later themes consume the Pulse score.

THEME	WHAT SHIPS
Deep PM Pulse	A composite engagement health score across schedule, cost, scope, risk, and stakeholder sentiment, with milestone-velocity tracking (accelerating, steady, or slipping), trend arrows and sparklines on the Control Tower and every project header, and weekly immutable Pulse snapshots. Engagements crossing a downward threshold are promoted to the top of the Control Tower and the Executive Hub.
Advanced telemetry & webhooks	Threshold and anomaly alerts on platform and engagement signals, delivered to tenant-configured webhook endpoints — HMAC-signed payloads, a replay window, and a dead-letter view — and to the in-app activity stream. Per-rule cool-down and a full delivery audit; endpoints are validated against SSRF, and payloads honor each tenant's financial masking.
Self-service Viewer widgets	A read-only widget library for the Viewer and guest tier — portfolio heat, milestone timeline, RAG summary, Pulse trend — with a composable personal landing view. Every widget renders through the same <code>restricted</code> masking and RBAC-scoped queries the tier already enforces, and adds zero write paths.

Each theme ships behind the same release discipline: migration rehearsal, a full green suite, a production build, and a tag at the deployed commit.

07 RESIDUAL ITEMS

Disclosed and tracked. None blocks production use.

ITEM	STATUS
WebAuthn / passkeys (phishing-resistant AAL2)	Tracked — TOTP is the interim second factor.
Legacy operator accounts unenrolled in MFA	Operator action — the hard cut-over means they enroll before they can elevate.
<code>FORCE ROW LEVEL SECURITY</code> on production	Post-soak — RLS is applied and enforced; <code>FORCE</code> follows the soak window.
Dedicated <code>a2r_ops</code> database role for the cross-tenant admin path	Phase-3 residual.
Third-party SOC 1 / SOC 2 attestation	Not started — the platform is control-aligned; attestation is a business decision.

Source of record: [docs/EXECUTIVE_SUMMARY.md](#) and [docs/ROADMAP.md](#). PS-DOS™ © 2026 A2R Ventures LLC. All rights reserved. Proprietary and confidential. Generated 2026-09-07 against commit e1a0c09 (tag v1.16.0).